

DevOrbit 威胁模型

范围与信任边界

保护对象包括生产凭据、代码工作区、审批决定、发布目标、Case State、证据引用和审计记录。Worker 输出、用户输入、Issue/日志内容与 RAG 文档均视为不可信；MCP 策略执行器、审批签发器和发布门禁属于受信控制面。

当前本地 Demo 的 HTTP x-devorbit-agent 只是会话绑定断言，不构成生产身份认证。生产部署必须由 Higress 或等价网关使用 mTLS/OIDC 工作负载身份认证并覆盖该 Header，随后将已认证主体映射到 config/tool-policy.json。真实凭据只由网关注入，不进入 Agent 上下文。

主要威胁与控制

威胁	攻击路径	预防控制	检测与恢复	当前证据 / 剩余风险
越权工具调用	RCA Agent 直接调用发布或写仓	服务端 Agent×Tool allowlist；默认拒绝	policyDecision=deny 审计和指标	SEC-001；本地身份由 Header 断言，生产需网关认证
审批伪造与重放	伪造审批号、跨 Case 重用回执	HMAC 签名、Case/Action/Approval scope、15 分钟过期	拒绝原因和审计引用	SEC-002..005；生产应使用 KMS 托管密钥和 nonce 持久化
Schema 混淆	注入隐藏命令或错误类型参数	输入/输出 Schema 运行时校验，拒绝未知字段	JSON-RPC -32602	SEC-006；复杂 Schema 可迁移标准 validator
路径穿越	Repo Tool 读取/写入工作区外文件	规范化路径并验证根目录前缀	MCP error audit	npm run mcp-smoke；容器级隔离列入复赛
Prompt / RAG 注入	Issue 或历史卡片诱导绕过策略	Agent 无权更改工具策略；RAG 只作为证据，不是授权	引用、低置信停止、人工升级	当前规则案例；需扩充专门注入语料
测试绕过	有失败仍进入发布	Verify 门禁和 Release 前置条件；服务端发布授权	消融显示关闭测试门禁准确/安全降至 85.7%	仿真数据，复赛扩展公开仓案例
灰度退化	不健康版本继续放量	确定性阈值与预置回滚，不由模型二次判断	灰度指标、回滚决定、知识卡	GC-006；真实集群执行待复赛接入
审计篡改	删除或改写不利证据	内容摘要、Case/Trace/Audit 关联、提交包校验	OTLP 导出与 SHA-256 清单	当前进程内 append-only；生产需 WORM/远端存储
敏感信息泄露	日志、Prompt、知识卡带密钥或个人信息	Worker 不持凭据，知识写入前脱敏契约	合规扫描和审计摘要	当前数据均为仿真；生产 DLP 未实现
资源耗尽	工具风暴、会话堆积、测试阻塞	会话上限/过期清理、测试超时、幂等缓存	时延与工具调用 Metrics	生产限流、配额和熔断需由网关补齐

Fail-closed 不变量

- 未授权 Agent 永远不能调用工具，即使参数有效。
- L2 发布没有有效、未过期且作用域匹配的审批回执时永远拒绝。
- 根因低于 0.80、必选测试失败或缺少回滚点时不得放量。
- L3 不可逆动作仅生成方案，不自动执行。

-
- 灰度指标越界执行预置回滚，不等待模型判断。
 - 所有允许、拒绝、重放和失败工具调用都生成审计记录。

机器可读策略见 [config/tool-policy.json](#)，对抗结果见 [reports/security-evaluation.json](#)。